DOP-C02 · 內容領域 6

安全性與合規

6.1 大規模身分與存取管理 · 6.2 自動化安全控制與資料保護
6.3 安全監控與稽核

17%

考試計分占比

依 AWS 官方考試指南（DOP-C02）重新整理

領域 6 總覽：三項任務陳述

6.1

大規模實施身分與存取管理技術

IAM 實體與政策類型 · 身分聯合 · 權限界限 · SCP · 最小權限 · RBAC / ABAC · 憑證輪換 · MFA 與 STS

6.2

以自動化實施安全控制與資料保護

網路安全元件 · 憑證與 PKI · 資料分類與加密 · 多帳戶安全控制 · 縱深防禦 · Macie · KMS / CloudHSM / ACM

6.3

實施安全監控與稽核解決方案

CloudTrail · Config · VPC 流量日誌 · 漂移偵測 · GuardDuty · Inspector · IAM Access Analyzer · 常見威脅與告警

IAM 實體：人員與機器存取的正確用法

實體 / 政策	用途	人員或機器
IAM 使用者	長期憑證；應盡量避免，改用聯合身分	少數例外（緊急存取、無法聯合的工具）
IAM 群組	把政策附加到一組使用者；本身不能被 assume	人員
IAM 角色	以 STS 取得臨時憑證；跨帳戶、服務、聯合存取	人員與機器
身分提供者（SAML / OIDC）	信任外部 IdP 或 OIDC 提供者（如 GitHub Actions）	人員與 CI/CD
身分型政策	附加在使用者、群組、角色上，定義能做什麼	—
資源型政策	附加在資源（S3、KMS、SQS、角色信任政策）上，可授權跨帳戶主體	—
工作階段政策	AssumeRole 時傳入，進一步縮小該次工作階段的權限	—

政策評估邏輯



三個關鍵原則

- 預設拒絕：沒有被允許就是拒絕
- 明確 Deny 永遠優先於任何 Allow
- SCP、權限界限、工作階段政策只設上限，本身不授權

跨帳戶存取

- 呼叫者帳戶的身分政策必須允許
- 目標資源的資源政策（或角色信任政策）也必須允許
- 兩邊都允許才能存取
- KMS 金鑰政策是必要條件：沒有金鑰政策授權，IAM 政策無效

身分聯合技術

AWS IAM Identity Center

- 多帳戶人員存取的建議做法
- 連接外部 IdP（Entra ID、Okta）：SAML 2.0 登入 + SCIM 自動佈建使用者與群組
- 權限集：在每個指派的帳戶自動建立角色
- 使用者入口網站、CLI 以 aws sso login 取得臨時憑證
- 可將使用者屬性傳入作為 ABAC 標籤

IAM 身分提供者

- SAML 2.0：企業 IdP 直接登入單一帳戶的角色（AssumeRoleWithSAML）
- OIDC：外部工作負載以權杖換取角色（AssumeRoleWithWebIdentity）
- CI/CD：GitHub Actions、GitLab 以 OIDC 取得臨時憑證，不需儲存存取金鑰
- EKS IRSA 也以 OIDC 提供者為基礎

OIDC 信任政策務必限制 sub 條件（例如只允許特定儲存庫與分支），否則任何使用同一提供者的儲存庫都能承擔該角色

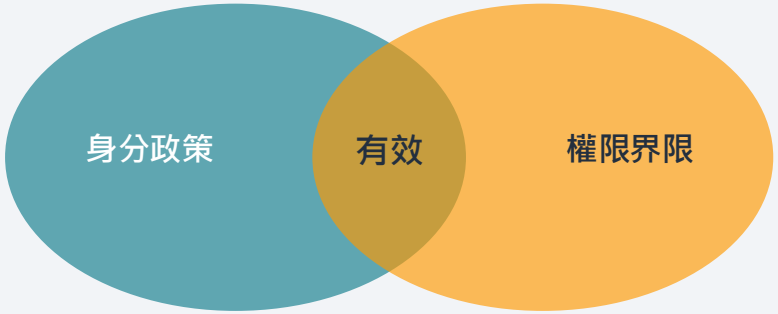
以權限界限委派權限管理

情境

開發團隊需要自行為 Lambda 建立 IAM 角色，但不能藉此建立比自己權限更大的角色（權限提升）

- 管理員建立界限政策（如 DevBoundary）
- 允許開發者 iam:CreateRole，但條件要求必須附加該界限
- 禁止開發者修改或移除界限政策

有效權限 = 身分政策 ∩ 權限界限



允許建立角色，但必須附加界限

```
{
  "Effect": "Allow",
  "Action": [
    "iam:CreateRole",
    "iam:PutRolePermissionsBoundary"
  ],
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "iam:PermissionsBoundary":
        "arn:aws:iam::111122223333:
         policy/DevBoundary"
    }
  }
}
```

組織的服務控制政策（SCP）

SCP：保護安全服務不被關閉

```
{
  "Effect": "Deny",
  "Action": [
    "cloudtrail:StopLogging",
    "cloudtrail:DeleteTrail",
    "guardduty:DeleteDetector",
    "config:StopConfigurationRecorder"
  ],
  "Resource": "*",
  "Condition": {
    "ArnNotLike": {
      "aws:PrincipalArn":
        "arn:aws:iam::*:role/SecurityAdmin"
    }
  }
}
```

限制區域

以 aws:RequestedRegion 拒絕未核准區域；全域服務（IAM、Route 53 等）需排除

防止離開組織

拒絕 organizations:LeaveOrganization，避免帳戶脫離治理

資源控制政策 RCP

從資源端限制，例如只允許組織內主體存取 S3、KMS

設計強制最小權限的政策

依活動產生政策

IAM Access Analyzer 分析 CloudTrail 紀錄，產生只含實際用到動作的政策

從實際使用出發

未使用的存取

Access Analyzer 找出未使用的角色、存取金鑰與權限；IAM 上次存取資訊

持續縮減

政策驗證與自訂檢查

在管道中驗證政策語法與安全建議；檢查是否授予新的存取或特定敏感動作

部署前把關

條件鍵縮小範圍

aws:SourceIp / aws:SourceVpce / aws:RequestedRegion / aws:PrincipalOrgID / aws:MultiFactorAuthPresent

限定情境

指定資源 ARN

避免 Resource: "*"；以路徑、前綴、標籤限縮

限定對象

從受管政策到自訂

先用 AWS 受管政策起步，再依實際使用改為自訂政策

逐步收斂

角色型（RBAC）與屬性型（ABAC）存取控制

RBAC 角色型

- 依職能建立角色或權限集（開發者、維運、稽核）
- 直觀、易於稽核
- 專案或資源增加時，政策數量隨之膨脹

ABAC 屬性型

- 依主體標籤與資源標籤是否相符授權
- 新專案只需加標籤，不必改政策
- 標籤可由 IdP 以工作階段標籤傳入

ABAC 條件：只能操作與自己同專案標籤的 EC2

```
"Condition": {
  "StringEquals": {
    "aws:ResourceTag/project": "${aws:PrincipalTag/project}"
  }
}
```

機器身分：自動輪換憑證

以角色取代長期存取金鑰

EC2	Lambda	ECS	EKS	本地伺服器	CI/CD
執行個體設定檔	執行角色	任務角色	IRSA / Pod Identity	IAM Roles Anywhere（X.509）	OIDC 聯合

Secrets Manager 自動輪換

- RDS、Aurora、Redshift 等支援受管輪換
- 其他密碼以 Lambda 輪換函數實作
- 排程：依天數或 cron 運算式
- 單一使用者或交替使用者策略，避免輪換時中斷

輪換流程（Lambda）

1. createSecret：產生新版本（AWSPENDING）
2. setSecret：在資料庫設定新密碼
3. testSecret：以新密碼測試連線
4. finishSecret：標記為 AWSCURRENT

控制人員與機器身分的存取：MFA、STS 與執行個體設定檔



MFA

多因素驗證

- 根使用者必須啟用 MFA，且不建立存取金鑰
- 以 aws:MultiFactorAuthPresent 條件要求敏感動作需 MFA
- CLI 使用者以 GetSessionToken 帶 MFA 取得臨時憑證
- Identity Center 可強制 MFA



AWS STS

臨時安全憑證

- AssumeRole：跨帳戶或切換角色
- AssumeRoleWithSAML / WithWebIdentity：聯合
- GetSessionToken：MFA 保護的工作階段
- 工作階段時間可設定；憑證自動到期
- 可傳入工作階段政策與標籤



IAM 執行個體設定檔

EC2 的角色容器

- 一個設定檔包含一個角色
- 應用程式透過執行個體中繼資料取得並自動更新憑證
- 強制使用 IMDSv2 防止 SSRF 竊取憑證
- 可在執行中的執行個體更換角色

網路安全元件

元件	層級	特性與用途
安全群組	ENI / 執行個體	有狀態；只有允許規則；可引用其他安全群組
網路 ACL	子網	無狀態（需設回應流量）；允許與拒絕；依規則編號順序評估
路由表	子網	控制流量走向（網際網路閘道、NAT、端點、防火牆）
AWS Network Firewall	VPC	有狀態檢查、IDS / IPS（Suricata 規則）、網域名稱篩選
AWS WAF	第 7 層	保護 CloudFront、ALB、API Gateway：SQL 注入、XSS、速率限制、受管規則
AWS Shield	DDoS	Standard 自動免費；Advanced 提供 SRT 支援、成本保護與進階偵測

AWS Firewall Manager：在整個組織集中套用 WAF、Shield Advanced、安全群組、Network Firewall 政策，新帳戶自動納管

組合安全控制，實現縱深防禦

邊緣 CloudFront ＋ ACM（TLS）＋ AWS WAF ＋ Shield

網路 Network Firewall、NACL、路由、VPC 端點

運算 安全群組、Inspector 弱點掃描、SSM 修補、IMDSv2

身分 最小權限 IAM、SCP、MFA、臨時憑證

資料 KMS 加密、Macie 敏感資料探索、S3 封鎖公開存取

偵測與回應 GuardDuty、Config 規則、Security Hub、Detective

憑證與公開金鑰基礎架構（PKI）

ACM 公開憑證

對外 TLS

- 免費，整合 ELB、CloudFront、API Gateway
- 以 DNS 驗證可自動續約
- CloudFront 使用的憑證必須在 us-east-1
- ACM 憑證屬於區域資源，每個區域需各自申請

AWS Private CA

內部 PKI

- 建立私有根 / 從屬憑證授權機構
- 簽發內部服務、mTLS、裝置憑證
- ACM 私有憑證可自動續約
- 可跨帳戶以 RAM 共用 CA

到期監控

避免憑證過期造成中斷

- 匯入的憑證不會自動續約
- ACM 會在到期前送出事件到 EventBridge
- Config 規則 acm-certificate-expiration-check
- 以 EventBridge + SNS 通知負責人

資料管理：分類、加密、金鑰管理與存取控制

面向	AWS KMS	AWS CloudHSM
租用模式	多租戶受管服務（FIPS 140-3 驗證 HSM）	專屬單一租戶 HSM 叢集
金鑰控制	AWS 管理硬體；客戶以金鑰政策控制使用	客戶完全掌控金鑰與 HSM 使用者
整合	與大多數 AWS 服務原生整合	標準 API（PKCS#11、JCE、CNG）；可作為 KMS 自訂金鑰存放區
何時選擇	絕大多數加密需求	法規要求專屬 HSM 或完全自行控制金鑰



KMS 重點

客戶管理金鑰：金鑰政策、授權（grants）、自動輪換、多區域金鑰；信封加密

靜態加密



傳輸中加密

TLS（ACM）；S3 儲存貯體政策以 aws:SecureTransport 拒絕 HTTP

傳輸中



分類與存取

以標籤標示資料等級，配合 ABAC 與 Macie 結果決定存取

依敏感度控制

以 Amazon Macie 大規模自動探索敏感資料



S3 儲存貯體清查

加密、公開存取、共用狀態



自動敏感資料探索

持續取樣分析整個 S3 資產



資料識別碼

受管識別碼（個資、金融）+ 自訂正規表示式



發現項目

送到 EventBridge 與 Security Hub



多帳戶

以 Organizations 委派管理員集中啟用並檢視所有帳戶

組織層級



敏感資料探索工作

針對特定儲存貯體一次性或排程深度掃描

深度檢查



自動回應

EventBridge 規則：發現敏感資料 → Lambda 加標籤、限制存取或通知

閉環處理

在多帳戶、多區域環境自動化套用安全控制



AWS Security Hub

中央組態政策：一次為整個組織啟用標準與控制；跨區域彙總；自動化規則調整發現項目

集中安全態勢



AWS Organizations

SCP / RCP 預防式控制；為各安全服務指定委派管理員帳戶

組織基礎



AWS Control Tower

依 OU 啟用預防式、偵測式、主動式控制；新帳戶自動套用

護欄



AWS Systems Manager

Quick Setup 組織層級設定、修補政策、Automation 跨帳戶與區域修正

作業系統層



AWS Firewall Manager

跨帳戶統一 WAF、安全群組、Network Firewall 政策

網路層



StackSets / 一致性套件

把 Config 規則、IAM 角色、偵測器設定部署到所有帳戶與區域

基準一致

安全稽核服務與功能

AWS CloudTrail

組織追蹤涵蓋所有帳戶與區域；日誌檔完整性驗證；資料事件；CloudTrail Lake 以 SQL 查詢

誰做了什麼 API

AWS Config

記錄資源組態歷史；規則與一致性套件；彙總器跨帳戶檢視

資源設定是否合規

VPC 流量日誌

記錄 ENI 的 IP 流量（ACCEPT / REJECT）；送到 CloudWatch Logs、S3 或 Firehose；不含封包內容

誰連了誰

CloudFormation 漂移偵測

找出堆疊資源被手動修改的差異；可排程並搭配 Config 規則

IaC 是否被繞過

識別安全弱點與事件的服務



Amazon GuardDuty

分析 CloudTrail、VPC 流量日誌、DNS 日誌；保護方案擴及 S3、EKS、執行時期、惡意軟體、RDS、Lambda

威脅偵測



Amazon Inspector

持續掃描 EC2、ECR 映像、Lambda 的軟體弱點與網路暴露

弱點管理



IAM Access Analyzer

外部存取：哪些資源被組織外部存取；未使用存取；政策檢查

存取風險



AWS Config

以規則偵測不安全設定，例如未加密、公開存取

設定風險



Amazon Detective

以行為圖譜調查發現項目的來龍去脈

調查



AWS Security Hub

彙整上述服務的發現項目，依標準評分

集中檢視

常見雲端安全威脅與自動化回應

威脅	偵測	自動化回應
不安全的網頁流量（HTTP）	Config 規則 alb-http-to-https-redirection-check	ALB 監聽器改為 HTTPS 轉址；CloudFront 檢視器政策強制 HTTPS
存取金鑰外洩	AWS Health 的 AWS_RISK_CREDENTIALS_EXPOSED 事件、GuardDuty	Lambda 停用金鑰、檢查 CloudTrail 活動、通知
S3 儲存貯體可公開存取	Config 規則、Access Analyzer、Macie	啟用封鎖公開存取（帳戶與儲存貯體層級）
S3 加密未啟用或非指定金鑰	Config 規則 s3-bucket-server-side-encryption-enabled	設定預設加密為 SSE-KMS；儲存貯體政策拒絕未加密上傳
根使用者被使用	CloudTrail + EventBridge / 指標篩選器	SNS 立即告警並調查
安全群組開放 0.0.0.0/0	Config 規則 restricted-ssh、Security Hub 控制	SSM Automation 移除規則

針對異常安全事件告警，並分析日誌與發現項目

EventBridge：GuardDuty 高嚴重度發現

```
{
  "source": ["aws.guardduty"],
  "detail-type": ["GuardDuty Finding"],
  "detail": {
    "severity": [{ "numeric": [">=", 7] }]
  }
}
```

CloudTrail 指標篩選器告警（CIS 建議）

- 未經授權的 API 呼叫
- 未使用 MFA 的主控台登入
- 根使用者活動
- IAM 政策、CloudTrail 設定、安全群組變更
- KMS 金鑰停用或排定刪除

分析工具

CloudTrail Lake / Athena

以 SQL 查詢稽核事件

CloudWatch Logs Insights

快速查詢近期日誌

Amazon Detective

關聯調查發現項目

Amazon Security Lake

以 OCSF 格式集中安全資料

情境練習

1. 員工以公司 IdP 登入多個 AWS 帳戶 [redacted]

2. GitHub Actions 部署不想存存取金鑰 [redacted]

3. 開發者可建角色但不可提升權限 [redacted]

4. 新專案不想一直新增 IAM 政策 [redacted]

5. 資料庫密碼每 30 天自動更換 [redacted]

6. 封鎖特定惡意 IP 存取子網 [redacted]

7. 防止 SQL 注入與惡意機器人 [redacted]

8. 找出 S3 中的信用卡號資料 [redacted]

9. 法規要求專屬 HSM 自行控制金鑰 [redacted]

10. 哪些 S3 儲存貯體被外部帳戶存取 [redacted]

情境練習

對照你的答案，再回頭複習對應任務

1. 員工以公司 IdP 登入多個 AWS 帳戶 — **IAM Identity Center**

2. GitHub Actions 部署不想存存取金鑰 — **OIDC 身分提供者**

3. 開發者可建角色但不可提升權限 — **權限界限**

4. 新專案不想一直新增 IAM 政策 — **ABAC 標籤**

5. 資料庫密碼每 30 天自動更換 — **Secrets Manager 輪換**

6. 封鎖特定惡意 IP 存取子網 — **NACL 拒絕規則**

7. 防止 SQL 注入與惡意機器人 — **AWS WAF**

8. 找出 S3 中的信用卡號資料 — **Amazon Macie**

9. 法規要求專屬 HSM 自行控制金鑰 — **AWS CloudHSM**

10. 哪些 S3 儲存貯體被外部帳戶存取 — **IAM Access Analyzer**

自我檢核：領域 6 官方目標

6.1	**IAM 實體與政策類型**	使用者、群組、角色、IdP、身分 / 資源 / 工作階段政策
6.1	**身分聯合與權限界限**	Identity Center、SAML、OIDC、權限界限
6.1	**SCP 與最小權限**	SCP 範例、Access Analyzer、條件鍵
6.1	**RBAC / ABAC 與憑證輪換**	標籤條件、Secrets Manager 輪換
6.1	**MFA、STS、執行個體設定檔**	aws:MultiFactorAuthPresent、AssumeRole、IMDSv2
6.2	**網路安全元件**	安全群組、NACL、Network Firewall、WAF、Shield
6.2	**憑證與 PKI**	ACM、Private CA、到期監控
6.2	**資料保護與加密**	KMS、CloudHSM、傳輸中加密、Macie
6.2	**多帳戶安全控制與縱深防禦**	Security Hub、Control Tower、Firewall Manager
6.3	**安全稽核**	CloudTrail、Config、VPC 流量日誌、漂移偵測
6.3	**弱點與事件識別**	GuardDuty、Inspector、Access Analyzer
6.3	**常見威脅、告警與分析**	金鑰外洩、公開 S3、EventBridge、CloudTrail Lake